



Video transcript

Information Assurance

Expert Insights – Strategy in Information Security: Richard Baskerville

Ahmad, A. and Baskerville, R. (2018). *Strategy in Information Security: Richard Baskerville* [Video file]. University of Melbourne. Retrieved from: <https://gomelb.unimelb.edu.au>

[MUSIC PLAYING]

ATIF AHMAD: Well, thank you, Professor Richard Baskerville, for making time to speak with us. My first question for you today is, how has the security landscape evolved in the past? And what challenges do you see in the future?

RICHARD BASKERVILLE: Well, in terms of the past, that's quite a long history. So if we go way back to the early days of computing, then we could talk about evolving out of a period when you used to be able to lock the door on a computer and that was the end of it. It was completely safe. You could put it in a Faraday shield, nothing would emanate out of it. There were no network connections, so your security was pretty complete.

Of course, we have evolved into a networked world, where security problems actually leak into the room across all the cabling and the wiring. So now we have serious security problems on any computer system because they're all networked together.

That's now evolving into a society today where virtually everything is becoming digital. We're surrounded in our lives by computing technology and digital technologies, all of which is vulnerable to security threats, to exploitation. And that means that we have to provide security for virtually all walks of life in terms of the digital devices that are mediating these walks of life.

So in terms of evolution over the life of our computing technology, it's now grown so that we are becoming inhabitants of a digital world in which many of our threats are digital threats.

ATIF AHMAD: So if you can perhaps elaborate on the recent past with-- we are seeing threats like ransomware, we're seeing threats like advanced persistent threat as a category. Now businesses are taking information security, or perhaps a new word, cybersecurity, much more seriously. What is happening now to the landscape? And how do you see this now projecting into the future?

RICHARD BASKERVILLE: Probably the biggest change is the sophistication of the attacks. And this simply arises from the increasing value attached to the assets that are represented in computing technologies. It's been a long time since money, the biggest part of our money, actually existed in any form other than a digital form. So when there is such value available, then the investment that an attacker is willing to make into exploiting the systems that contain this value in order to transfer the assets are immense.

And that means that the attacks are growing in sophistication. They're growing more difficult against which to defend. And that means that the investment that needs to be made in information security by any organisation that is dependent on these technologies-- and that's most of them-- has to be much larger. And the sophistication of their defence systems has to be much greater.

Current as of: July, 2018.



Probably, one end of the spectrum, you've got nation states, which have to protect themselves against computer attacks, information warfare. At the other end of the spectrum, you've got small, medium businesses-- SMBs-- who must struggle to survive the risks that they're faced in maintaining their own businesses.

ATIF AHMAD: So would you say that the sophistication of the attacks is being met by a sophisticated response?

RICHARD BASKERVILLE: I think I would say that this is changing. And it's changing because the sophistication of the attacks is rising. And there is a lag between the rise of the sophistication of the attacks and the rise of the sophistications of the responses. So what we must inevitably see is investments in the responses that-- just definitionally they're responses.

Those responses are always going to lag the sophistication of the attacks. It's becoming increasingly difficult to anticipate the sophistication of the next attack, and more difficult to put into place safeguards against an attack that you haven't seen yet. So we'll always see a sophistication of the attacks on the rise as long as digitization is going to continue, or digitalization is going to continue. And the sophistication of the responses will always be in a catch-up mode.

ATIF AHMAD: In your security publications, you've described the business information system security paradigm and the information warfare paradigm. And you've compared and contrasted the paradigms. So for our listeners, can you explain what these paradigms are, and specifically, the distinctions between these two, and how they relate to the context of this discussion around defence and attack?

RICHARD BASKERVILLE: Well, first of all, I reserve the right to have changed my mind over the period of time, at least progressively. And that's because the relationship between these two paradigms has been shifting. So I can talk about 10 years ago, in which there was a dramatic difference between the two paradigms.

The business information system security paradigm was based on prevention and on risk management. It had this notion of variance, like you're dealing with variables. So if I increase my level of prevention, then I'll decrease my risk. That was really the mindset. Most of the safeguards and controls that were put in business systems were based on reducing this probability of a security loss. That's the business information systems paradigm of 10 years ago.

The warfare paradigm of 10 years ago was evolving into one in which your attacker was expected to be significant. You attacker was expected to be innovative and creative. That's because the attacker was really a nation state with a lot of resources to put toward the attack.

So the attack would be based on the unnoticed vulnerabilities of your adversary. The attack would be based on the unexpected attack. It would be created specifically for attacking that particular victim.

The result of that was that in a warfare paradigm, the defender had to be prepared to invent a response very quickly on the fly. It was all about agility. So it was less emphasis on the prevention of the attack, but more emphasis on responding to a successful attack because it was unexpected. It was directed against your unnoticed vulnerabilities. So you had to be able to respond quickly to prevent the attack from spreading to other resources to prevent the attack from occurring again.

So the information warfare paradigm and the business paradigm are quite distant. Today, because of this digitalization that I mentioned earlier, there is increasing value in the information assets of the business world. More of our business

Current as of: July, 2018.



value is being not just retained on these information systems, but generated by these information systems. So they're more valuable, exploiting those from an attack viewpoint has become a more valuable exercise. So it's something you're willing to invest more.

So now, we find ourselves today in an arena in which the attacks that used to be levied only in a military environment are beginning to be seen in a business environment. And we're calling these today Advanced Persistent Threats-- APTs. They're severe. They're levied, as were the military ones. They're levied against unnoticed vulnerabilities. They're unexpected kinds of attacks.

And that means the business information systems now need to have this sort of balance between preparation and prevention, which is traditional. But now this kind of response, this agility, to be able to compensate for an attack that's going to succeed because it's unanticipated. So incident response now becomes more important in the BISS than it used to be.

ATIF AHMAD: In your opinion, are organisations are aware of these two paradigms? Is their security strategy drawing on these two paradigms, or are they still stuck in the old BISS paradigm, where they're investing into security hoping that their risk profile will be reduced correspondingly?

RICHARD BASKERVILLE: Well, anything that's in transition is in transition. So some organisations are going to be well prepared. They may have seen these sorts of attack coming. They may have been victims already of these kinds of attacks. The finance industry, as you might expect, is among the first of the victims. So they're now investing more into their security efforts, which means they're still boosting their preventative kinds of controls, but they're also putting into place more responsive kinds of controls-- those that enable them to react.

But there are still plenty of organisations out there that are stuck in the old mode. Either they've been lucky and haven't been attacked, or they're not noticing what's going on in their industries, and they haven't made the investments in the response of kinds of security that they really should be doing out of responsibility for their shareholders.

And it's also an issue where if you were a small or medium enterprise, they may not have the resources to put into place the responsive and agile kinds of security that larger organisations may have available. So they end up operating in a riskier profile.

ATIF AHMAD: So my last question to you is, security managers frequently ask us for advice on how to make a case or how to approach senior management that don't take information security seriously. What advice could you possibly give them?

RICHARD BASKERVILLE: I think the main thing to try to do is inform them. So you provide as much information as you can-- information about losses of other organisations in their own industry, information about the kinds of attacks that have succeeded in other kinds of organisations or other industries, information about the cost of the safeguards, the nature of the safeguards that need to be put into place, and how to organise those.

For example, if you're informing such organisations about the kind of security they would need for today, there would be an understanding of what an incident response team requires, what resources have to be in place-- an understanding that the management strategy of security has shifted from one that's been purely preventative to one that now has required more agility and more responsive, that needs to be planning put in place. It's the planning that is on the one hand, the most necessary, and on the other hand, the most expensive because your resources have to be developed and put into place for that.



So it's my view-- unless the organisation has a major loss, it's all about informing them, making sure they're aware of their losses. If they've had a major loss, then you don't have to convince them anymore. They've learned it. And as you know, Atif, when you walk into an organisation that's had a major loss, you're the best friend. When you walk into an organisation that hasn't had that experience, you're a salesman.

ATIF AHMAD: Thank you very much for taking time out to speak to us.

RICHARD BASKERVILLE: You're very welcome.

END TIMECODE: 14:09